

Data Retention and Disposal Policy

EZER · 7308 Forest Bend Drive, Parker, Texas

Version 1.0 · Effective 7 September 2026 · Next scheduled review 7 September 2027

Owner: Founder / Data Protection contact · daniel4chigs@gmail.com

1. Purpose and scope

This policy governs how long EZER retains personal data, how that data is disposed of, and who is accountable for both. It covers all personal data processed by the EZER mobile application and its backend API, including data obtained from Plaid Inc. and from user-authorised email mailboxes. It applies to production databases, backups, object storage, and application logs.

2. Governing principle

EZER retains personal data only for as long as it is needed for the purpose it was collected for, or for as long as a legal, tax, or accounting obligation requires. Data that no longer meets either test is deleted. Retention periods are set out in section 3 and are not extended without a documented reason.

3. Retention schedule

DATA	RETENTION	TRIGGER FOR DISPOSAL
Account record (email, name, password hash)	Life of account	User-initiated deletion
Consent record (timestamp, policy version)	Life of account + 3 years	Evidentiary retention, then purge
Plaid access tokens	Until the connection is removed	Disconnect or account deletion; revoked upstream first
Bank transactions and balances	Life of account	Account deletion; cascade
Email-derived subscription data	Life of account	Mailbox disconnect or account deletion
Raw email message bodies	Not retained	Parsed in-process; only extracted fields are stored
Savings goals, transfers, ledger entries	7 years	Financial recordkeeping obligation
Application and error logs	30 days	Automatic rotation

Encrypted database backups	30 days	Automatic rotation
----------------------------	---------	--------------------

Where a record is subject to both a deletion request and a statutory retention obligation — principally the seven-year financial records above — the record is retained for the statutory term but is disassociated from the deleted user's identifiers.

4. Disposal procedure

Deletion is executed by the application, not by manual database access. A user requests deletion in the app, which calls `DELETE /account`. That endpoint:

- Revokes every Plaid Item upstream via `/item/remove` *before* local records are destroyed, so no connection is left live and unaddressable;
- Deletes the user record, which cascades through every user-owned table — authentication accounts, OAuth tokens, Plaid items, funding sources, transactions, subscriptions, savings goals, transfers, and ledger entries — by foreign-key constraint rather than by an application-maintained list that can drift;
- Logs the outcome, including any Plaid item that could not be revoked, for manual follow-up.

Deletion from the primary database is immediate. Encrypted backups containing the record are purged on the 30-day rotation described above, after which no copy remains. Personal data is never disposed of by transfer to a third party.

5. Data subject rights

Users may exercise the following at any time from within the application, without contacting support:

- **Access / portability** — `GET /account/export` returns the user's data as JSON. Credential material is excluded.
- **Erasure** — `DELETE /account`, as described above.
- **Withdrawal of consent** — disconnecting a bank or mailbox halts collection from that source.

Requests received by email are actioned within 30 days, consistent with GDPR Article 12(3) and the CCPA/CPRA. EZER does not charge for these requests and does not discriminate against users who make them.

6. Consent

Users must affirmatively accept the Terms of Service and Privacy Policy before an account is created. Acceptance is recorded durably against the user record as a timestamp and a policy version identifier, so it can be evidenced per user and per document version. This applies to both email registration and social sign-in. Consent for access to bank data is captured separately by Plaid Link at the moment of connection; consent for mailbox access is captured by the provider's own OAuth consent screen and is optional.

7. Security of data at rest

- Passwords are stored only as bcrypt hashes and are not recoverable.
- Plaid access tokens are encrypted at rest under a key held separately from the database and supplied by environment configuration; the API refuses to start in production if that key is absent.
- All data is encrypted in transit over TLS.
- Production access is restricted to the policy owner and is logged.

8. Accountability and review

The policy owner named above is accountable for enforcement. This policy is reviewed at least annually, and additionally whenever EZER adds a data category, a sub-processor, or a jurisdiction. Each review records the date, the reviewer, and any change. Version 1.0 is the initial issue; the next scheduled review is 7 September 2027.

9. Sub-processors

SUB-PROCESSOR	PURPOSE	DATA
Plaid Inc.	Bank connectivity	Financial account and transaction data
Supabase	Managed Postgres	All stored personal data
Railway	API hosting	Data in transit and in memory; logs
RevenueCat, Apple, Google	Subscription billing	Purchase status; no financial account data

Sub-processors are bound by their own data protection terms. Adding one triggers a review of this policy under section 8.

EZER

7308 Forest Bend Drive, Parker, Texas

daniel4chigs@gmail.com